UNIVERSIDAD NACIONAL DE SAN AGUSTÍN

FACULTAD DE INGENIERÍA DE PRODUCCIÓN Y SERVICIOS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



ACTIVIDAD PRÁCTICA

Trabajo de Investigación Formativa: Sistema de Soporte a PIMS según ISO/IEC 27701

ASIGNATURA

AUDITORÍA DE SISTEMAS

GRUPO 4

DOCENTE

EDWARD VICENTE ZARATE CARLOS

INTEGRANTES

JHOSSEP FABRITZIO VELARDE SALDAÑA

JOHANN ANDRE CACERES RUIZ

CHRISTIAN RAUL MESTAS ZEGARRA

MARIEL ALISSON JARA MAMANI

AREQUIPA - PERÚ

2026

Trabajo de Investigación Formativa: Sistema de Soporte a PIMS según ISO/IEC 27701

Parámetro	Detalle y Especificación Técnica
Turno	B
Grupo	4
Nombre del Agente	**Agente de Incidentes** (Autonomous PIMS Incident Orchestrator & Glass-Box Cockpit)
Cláusulas y Controles de ISO/IEC 27701:2025 *(Aplicables al manejo de incidencias y cobertura de este sistema)*	El sistema implementa una arquitectura autónoma de gobierno, respuesta y auditoría forense alineada con los requisitos y controles de ISO/IEC 27701:2025: • **Cláusula 5.3 (Roles, responsabilidades y autoridades):** Definición de 8 roles operativos especializados con hashes SHA-256 de prompts versionados, principio de mínimo privilegio en herramientas y registro inmutable en `tool_ledger`. • **Cláusulas 6.1.2 y 8.2 (Evaluación de riesgos de privacidad):** Evaluación automática del impacto sobre los derechos de los titulares (PII principals), clasificación de severidad y detección de categorías sensibles de datos expuestos (DNI, biometría, credenciales). • **Cláusulas 6.1.3 y 8.3 (Tratamiento de riesgos de privacidad):** Generación y ejecución determinista de planes de contención, aislamiento de sistemas y salvaguardas inmediatas. • **Cláusula 7.5 (Información documentada - 7.5.1, 7.5.2, 7.5.3):** Repositorio de evidencias forenses cifrado en reposo (AES-256-GCM), encadenamiento de hashes SHA-256 y sellado canónico de paquetes en PostgreSQL. • **Cláusula 9.1 (Seguimiento, medición, análisis y evaluación):** Demonio **watcher** continuo, reloj de cuenta regresiva de 72 horas para plazos regulatorios y telemetría de estado. • **Cláusula 10.2 (No conformidad y acción correctiva):** Análisis de causa raíz (RCA) estructurado, recomendaciones de medidas correctivas y lista de chequeo de cierre de 8 puntos. • **Control A.3.11 / B.3.11 (Planificación y preparación de gestión de incidentes):** Procedimientos preestablecidos de ingesta vía API PIMS (E01-E26) y compuerta **fail-closed** de redacción PII con Microsoft Presidio (`PE_DNI`, `PE_RUC`, teléfonos). • **Control A.3.12 / B.3.12 (Respuesta a incidentes de seguridad de la información):** Determinación de brecha; redacción de paquetes de notificación a autoridades (GDPR Art. 33); avisos a titulares en lenguaje claro analizados con `Intl.Segmenter` (GDPR Art. 34); y evaluación de exenciones estatutarias según Art. 34(3). • **Dual-Modal RAG Normativo:** Fundamentación de decisiones con citas textuales exactas (`doc_id:chunk_id:lines`) del estándar mediante pgvector + MiniSearch BM25 y reranking cruzado.
Enlace del Sistema	incidents-pims.mistercricro8.top
Credenciales de Acceso	**Usuario:** `grupob4` **Contraseña:** `Q^*aLefm8gyBf3N^`